TEK-UP University

École Supérieure Privée d'Ingénierie et de Technologie

Cycle ingénieur · Sécurité des Systèmes Informatiques et Réseaux (SSIR)

RAPPORT DE MINI-PROJET

Réponse à incident et investigation numérique (DFIR)

Simulation d'une compromission par phishing et exfiltration de données

Réalisé par

Chaima Romdhani

Classe : ING-5-J-SSIRF-D

Année universitaire 2026 – 2027

Introduction

Les cyberattaques ne cessent de se multiplier et de gagner en sophistication, ciblant aussi bien les grandes organisations que les petites structures. Dans ce contexte, savoir réagir face à une compromission est devenu une compétence incontournable : il ne suffit plus de se protéger, il faut aussi être capable de détecter une intrusion, de comprendre ce qui s'est réellement passé et d'y remédier efficacement. C'est précisément l'objet de la réponse à incident et de l'investigation numérique (DFIR — *Digital Forensics and Incident Response*), qui regroupe l'ensemble des méthodes permettant d'analyser une attaque à partir des traces qu'elle laisse derrière elle.

Ce projet met en place un laboratoire de cybersécurité isolé afin de rejouer une attaque informatique réaliste, de la détecter et de l'analyser de bout en bout. Concrètement, on joue deux rôles complémentaires : celui de l'**attaquant**, qui compromet une machine via un e-mail de phishing puis vole des données, et celui de l'**analyste**, qui enquête sur l'incident pour reconstituer ce qui s'est passé et le prouver. L'attaque est menée depuis une machine Kali contre une victime Windows, pendant qu'une station d'analyse Ubuntu surveille et investigue en continu.

L'idée directrice tient en une règle simple : **chaque action de l'attaquant laisse une trace** — en mémoire, sur le disque, sur le réseau ou dans les journaux — et c'est précisément ce que l'investigation s'attache à retrouver. En combinant la détection en temps réel (Wazuh, Suricata) et l'analyse forensique approfondie (Volatility, YARA), le projet démontre la maîtrise complète du cycle DFIR : détecter, analyser, prouver, puis remédier, où chaque conclusion repose sur une preuve technique vérifiable.

1. Scénario de l'incident

Le scénario retenu reproduit une attaque parmi les plus courantes en entreprise : la compromission d'un poste de travail par **phishing**, suivie du **vol de données sensibles**. Il a été conçu pour rester simple et réaliste, tout en couvrant les grandes phases d'une véritable intrusion.

L'histoire est la suivante. Un employé reçoit un e-mail frauduleux contenant une pièce jointe piégée, présentée comme une facture impayée (Facture_Impayee_Octobre2026.exe). Pensant ouvrir un document légitime, il l'exécute. En réalité, le fichier lance discrètement un programme malveillant qui ouvre une connexion vers la machine de l'attaquant : celui-ci prend alors le **contrôle à distance** du poste. Fort de cet accès, l'attaquant explore la machine (**reconnaissance**), installe une **porte dérobée** pour conserver son accès même après un redémarrage (**persistance**), puis rassemble et **exfiltre des fichiers sensibles** vers son propre serveur.

Pendant toute la durée de l'attaque, la machine victime est surveillée : chaque action laisse une empreinte quelque part — un processus créé, une clé de registre modifiée, une connexion

réseau établie, un fichier déposé. C'est à partir de ces traces que l'investigation reconstruit, étape par étape, le déroulé complet de l'incident. Le détail technique de chacune de ces phases, ainsi que les preuves associées, est présenté dans la partie **Résultats**.

2. Architecture

Le laboratoire repose sur **trois machines virtuelles** connectées entre elles sur un **réseau isolé** de type *host-only* (10.10.10.0/24), complété par une interface NAT utilisée uniquement pour l'installation des outils. Cette isolation est volontaire : elle garantit qu'aucun trafic malveillant ne peut sortir de l'environnement de test, condition indispensable pour rejouer une attaque réelle en toute sécurité.

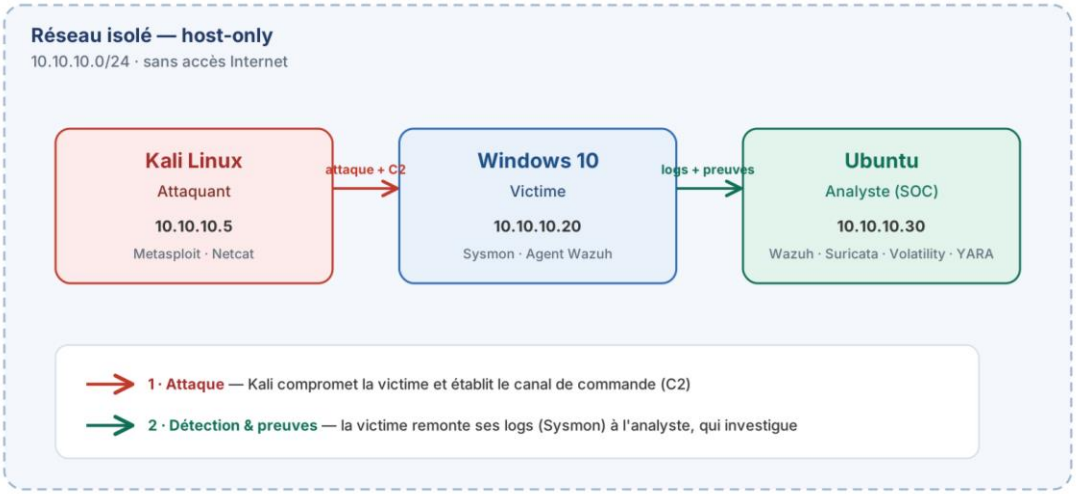


Figure 1 — Architecture du laboratoire DFIR sur réseau isolé.

Chaque machine joue un rôle précis dans le scénario :

Machine	Adresse IP	Rôle
Kali Linux	10.10.10.5	Attaquant
Windows 10	10.10.10.20	Victime
Ubuntu	10.10.10.30	Analyste (station centralisée)

Le fonctionnement d'ensemble suit une logique simple. La machine **Kali** mène l'attaque contre la **victime Windows**. Cette dernière est instrumentée avec **Sysmon** (qui journalise finement l'activité du système) et un **agent Wazuh** qui remonte ces événements en temps réel vers la station d'analyse. La machine **Ubuntu** joue le rôle de centre de supervision et d'investigation : elle centralise à la fois la **détection en temps réel** (grâce au SIEM Wazuh et à l'IDS réseau Suricata) et l'**analyse forensique approfondie** (mémoire avec Volatility, fichiers avec YARA). Cette organisation reproduit, à échelle réduite, l'architecture d'un véritable **SOC** (Security Operations Center), où la détection et l'analyse sont regroupées sur une station dédiée.

3. Méthodologie

L'investigation s'appuie sur le cycle de réponse à incident **NIST SP 800-61**, référentiel reconnu qui structure la démarche en quatre grandes phases : **Préparation**, **Détection & Analyse**, **Confinement–Éradication–Récupération**, et **Post-incident**. Cette méthodologie garantit une approche rigoureuse et reproductible, où chaque étape de l'enquête s'enchaîne logiquement.

Concrètement, la démarche suivie dans ce projet se décline ainsi :

- **Préparation** : mise en place du laboratoire isolé, instrumentation de la victime avec Sysmon, et déploiement des outils de détection (SIEM Wazuh et IDS Suricata) sur la station d'analyse.
- **Détection & Analyse** : surveillance de l'attaque en temps réel grâce à Wazuh et Suricata, qui remontent les alertes au fur et à mesure que l'attaque se déroule.
- **Collecte des preuves** : capture des éléments dans le respect de l'**ordre de volatilité** (la mémoire vive en priorité, car elle disparaît à l'extinction), avec un **hachage SHA-256** systématique et la tenue d'une **chaîne de custody** garantissant que les preuves n'ont pas été altérées.
- **Investigation forensique** : analyse approfondie des preuves : la mémoire avec Volatility, le trafic réseau avec Suricata, les journaux avec Wazuh, et le fichier malveillant avec YARA.
- **Remédiation** : définition du plan de confinement, d'éradication et de reprise pour clôturer l'incident.

Tout au long de l'analyse, les techniques employées par l'attaquant sont caractérisées selon le référentiel **MITRE ATT&CK**, standard international qui classe les comportements d'attaque en tactiques et techniques. Cette caractérisation permet de décrire l'incident dans un langage commun aux professionnels de la cybersécurité, et de relier chaque action observée à une technique d'attaque identifiée.

4. Outils utilisés

Le projet mobilise un ensemble d'outils complémentaires, chacun intervenant à un moment précis du cycle et sur une source de preuve différente. Certains servent à mener l'attaque, d'autres à la détecter en temps réel, et d'autres encore à l'analyser en profondeur.

Outil	Machine	Rôle
Metasploit	Kali	Génération du fichier malveillant et établissement du canal de contrôle à distance (C2)
Sysmon	Victime	Journalisation détaillée de l'activité du système (processus, réseau, registre)

Magnet RAM Capture	Victime	Capture de la mémoire vive pour analyse forensique
Wazuh (SIEM)	Ubuntu	Centralisation des journaux, détection en temps réel et caractérisation MITRE ATT&CK
Suricata (IDS)	Ubuntu	Surveillance et détection du trafic réseau
Volatility 3	Ubuntu	Analyse de la mémoire vive (processus, connexions, injections)
YARA	Ubuntu	Classification et identification du fichier malveillant

Ces outils ne fonctionnent pas isolément : c'est leur **combinaison** qui fait la force de l'investigation. Sysmon et Wazuh assurent la détection « côté machine », Suricata surveille le réseau, Volatility plonge dans la mémoire, et YARA confirme la nature du malware. Aucun ne suffit à lui seul à reconstituer l'incident ; c'est en croisant leurs résultats que l'on parvient à reconstruire et à prouver l'intégralité de l'attaque — exactement comme le ferait une véritable équipe de sécurité.

5. Résultats

Cette partie reconstitue l'attaque étape par étape. Pour chaque phase, on décrit l'action menée par l'attaquant, la trace qu'elle génère, et la preuve technique qui permet de la confirmer. Le tableau ci-dessous résume la chaîne d'attaque complète, caractérisée selon le référentiel MITRE ATT&CK.

Étape	Technique MITRE ATT&CK	Trace générée
Phishing / livraison	T1566 – Phishing	Fichier Facture_Impayee_Octobre2026.exe
Exécution	T1204 – User Execution	Création de processus (Sysmon)
Prise de contrôle (C2)	T1071 – Application Layer Protocol	Connexion 10.10.10.20 → 10.10.10.5:4444
Reconnaissance	T1033 / T1087 – Discovery	whoami, net user, ipconfig, systeminfo
Persistance	T1547.001 – Registry Run Key	Clé de registre WindowsUpdate
Exfiltration	T1041 – Exfiltration Over C2	Vol des fichiers du dossier Confidentiel

5.1 Préparation de l'attaque (côté Kali)

Depuis la machine attaquante, un fichier exécutable piégé est fabriqué à l'aide de l'outil msfvenom de Metasploit, sous le nom trompeur Facture_Impayee_Octobre2026.exe. Ce fichier contient un payload Meterpreter configuré pour se connecter en retour à l'attaquant (adresse 10.10.10.5, port 4444) :



Figure 2 — Génération du payload malveillant avec msfvenom (Facture_Impayee_Octobre2026.exe).

L'attaquant met ensuite en place un gestionnaire d'écoute (handler) qui attend la connexion de la victime, ainsi qu'un serveur web qui sert à livrer le fichier :

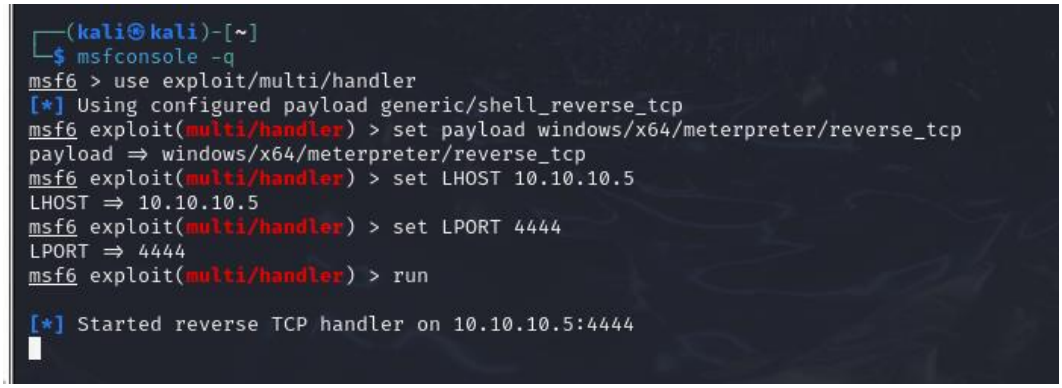


Figure 3 — Mise en écoute du gestionnaire Metasploit (reverse TCP handler sur 10.10.10.5:4444).

Ce fichier est ensuite **envoyé à la victime par un e-mail de phishing**, présenté comme une facture impayée à régler. L'objectif est d'inciter l'employé à ouvrir la pièce jointe sans méfiance.

5.2 Livraison et exécution

La victime télécharge puis exécute le fichier, simulant l'ouverture d'une pièce jointe d'e-mail de phishing. Dès l'exécution, une session Meterpreter s'ouvre côté attaquant : le canal de commande et contrôle (C2) est établi.

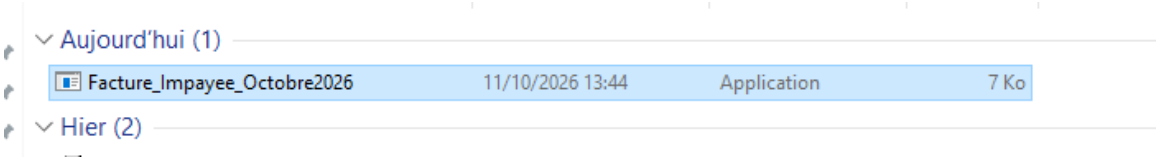


Figure 4 — Le fichier malveillant déposé dans le dossier Téléchargements de la victime (7 Ko).

À l'exécution du fichier, une session Meterpreter s'ouvre côté attaquant : le canal de contrôle à distance (C2) est établi et la machine est compromise :



Figure 5 — Ouverture de la session Meterpreter : prise de contrôle à distance de la victime (10.10.10.20).

5.3 Reconnaissance

Une fois le contrôle obtenu, l'attaquant explore la machine pour comprendre son environnement : identité de l'utilisateur, comptes présents, configuration réseau, informations système et processus en cours.

L’attaquant explore d’abord l’identité de l’utilisateur et les comptes présents sur la machine :



Figure 6 — Reconnaissance initiale : sysinfo, getuid, whoami, net user.

Il récupère ensuite la configuration réseau du poste :

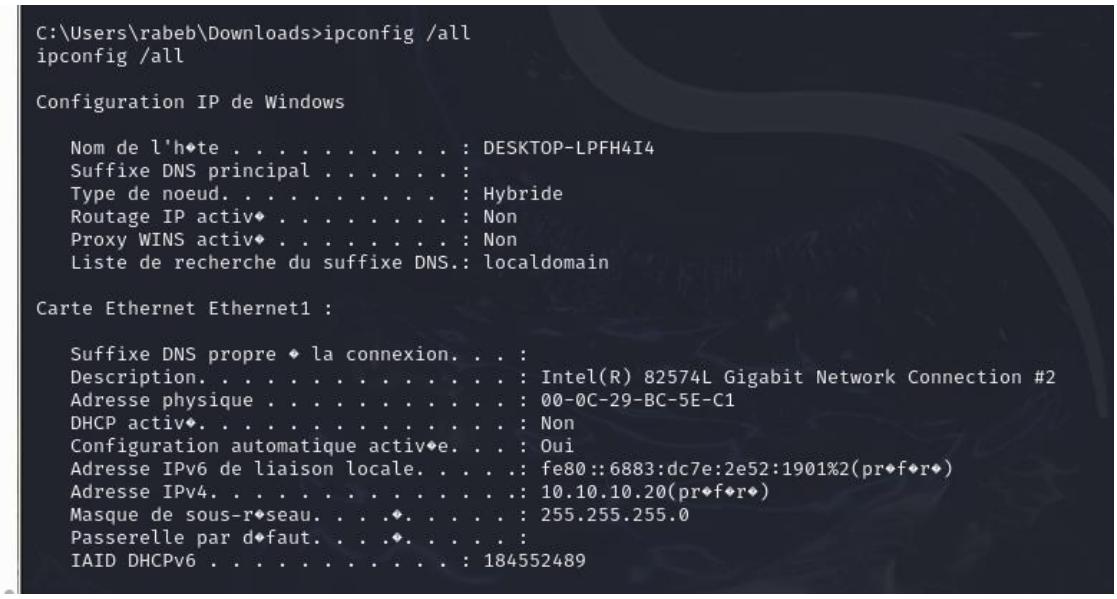


Figure 7 — Reconnaissance réseau : ipconfig /all.

5.4 Persistance

Pour conserver son accès même après un redémarrage, l'attaquant crée une clé de registre dans HKCU\...\CurrentVersion\Run, nommée « WindowsUpdate » et pointant vers le malware. Cette technique correspond à MITRE ATT&CK **T1547.001 (Registry Run Key)** :

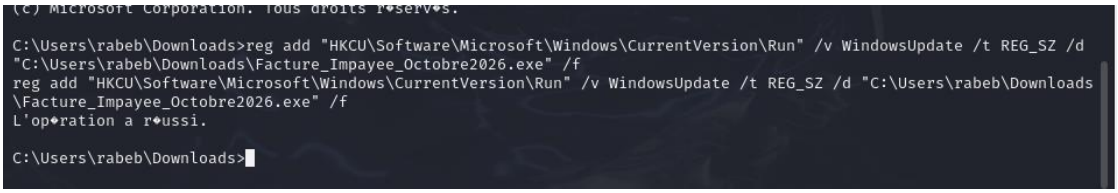


Figure 8 — Création de la clé de persistance « WindowsUpdate » dans le registre.

5.5 Exfiltration

L'attaquant rassemble de faux fichiers sensibles (données bancaires, mots de passe, contrats) dans un dossier « Confidentiel », puis les exfiltre vers sa machine via le canal C2 (technique T1041).

L'attaquant rassemble de faux fichiers sensibles (données bancaires, mots de passe, contrats) dans un dossier ciblé :

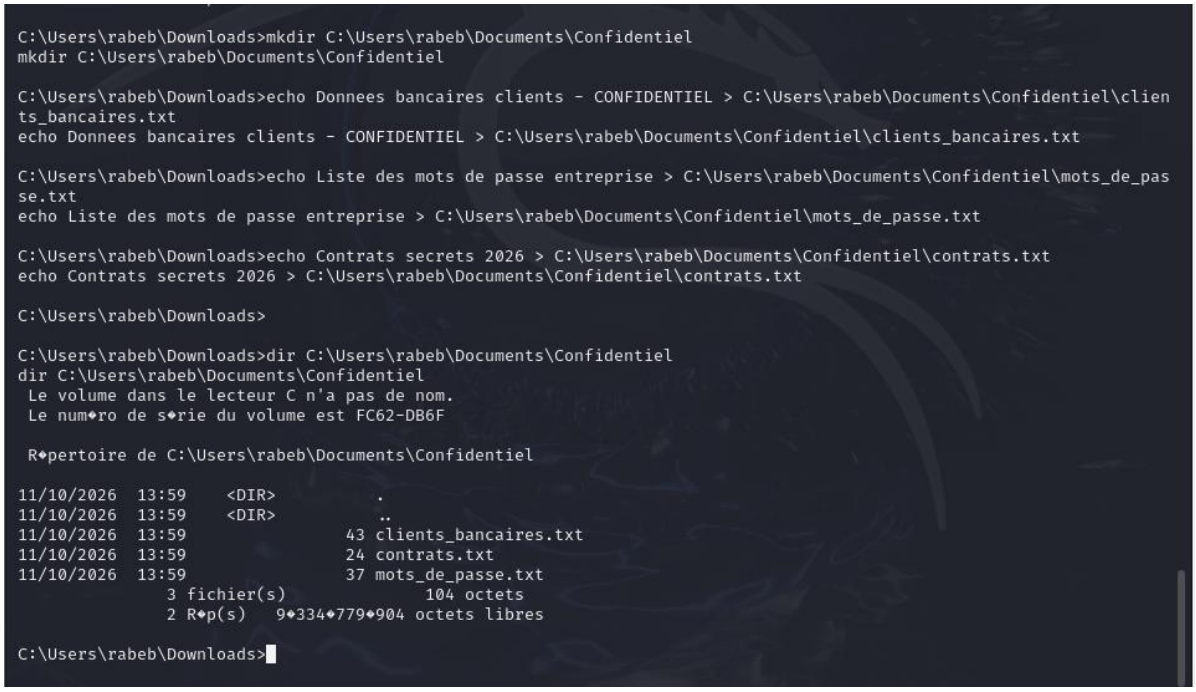


Figure 9 — Création du dossier et des fichiers sensibles ciblés sur la victime.

Il exfiltre ensuite ces fichiers vers sa propre machine à travers le canal C2 :

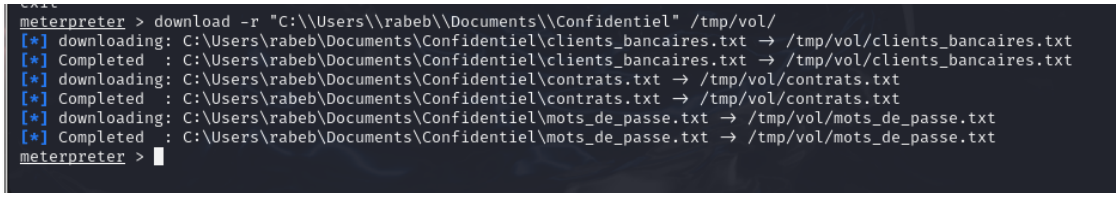


Figure 10 — Exfiltration des fichiers sensibles vers l'attaquant (commande download de Meterpreter).

5.6 Collecte des preuves

Conformément à l'ordre de volatilité, la mémoire vive est capturée en priorité, pendant que le malware est actif, à l'aide de Magnet RAM Capture. L'empreinte SHA-256 est calculée sur la victime puis vérifiée après transfert vers la station d'analyse, garantissant l'intégrité de la preuve (chaîne de custody).

La mémoire vive de la victime est capturée pendant que le malware est actif, puis son empreinte SHA-256 est calculée pour garantir son intégrité :

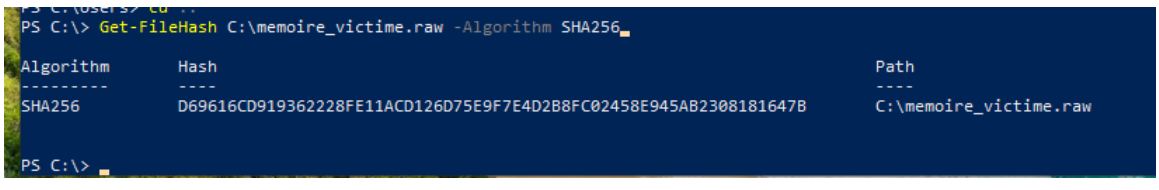


Figure 11 — Calcul de l'empreinte SHA-256 du dump mémoire sur la victime.

Après transfert vers la station d'analyse, l'empreinte est re-vérifiée : elle est identique, ce qui prouve que la preuve n'a pas été altérée :

```
ubuntu@ubuntu:~/preuves$ cd ~/preuves
ubuntu@ubuntu:~/preuves$ ls -lh memoire_active.raw
-rw-rw-r-- 1 ubuntu ubuntu 2.0G Oct 11 09:35 memoire_active.raw
ubuntu@ubuntu:~/preuves$ sha256sum memoire_active.raw
d69616cd919362228fe11acd126d75e9f7e4d2b8fc02458e945ab2308181647b  memoire_active.raw
ubuntu@ubuntu:~/preuves$
```

Figure 12 — Vérification de l'intégrité après transfert : l'empreinte est identique (preuve non altérée).

5.7 Analyse mémoire — Volatility

L'analyse du dump mémoire avec Volatility 3 permet de reconstruire l'activité du malware. Elle confirme la présence du processus malveillant, sa connexion au serveur de l'attaquant et sa filiation.

Volatility identifie d'abord le système analysé à partir du dump mémoire :

```
Variable        Value

Kernel Base     0xf80315813000
DTB     0x1ad000
Symbols file:///home/ubuntu/.local/lib/python3.8/site-packages/volatility3/symbols/windows/ntkrnlmp.pdb/F57E740B088E5056E8AF0772F1CC5BEB-1.json.xz
Is64Bit True
IsPAE   False
layer_name      0 WindowsIntel32e
memory_layer    1 FileLayer
KdVersionBlock  0xf80316422400
Major/Minor     15.19041
MachineType     34404
KeNumberProcessors      2
SystemTime      2026-10-11 16:21:49
NtSystemRoot    C:\Windows
NtProductType   NtProductWinNt
NtMajorVersion  10
NtMinorVersion  0
PE MajorOperatingSystemVersion  10
PE MinorOperatingSystemVersion  0
PE Machine      34404
PE TimeDateStamp        Sat Feb  2 23:04:03 1985
ubuntu@ubuntu:~/preuves$
```

Figure 13 — Volatility — windows.info : identification du système analysé à partir de la mémoire.

L'analyse approfondie confirme la connexion C2 vers l'attaquant (10.10.10.5:4444) et montre que le malware a été lancé depuis l'Explorateur Windows (explorer.exe → Facture_Impayee), validant l'ouverture manuelle du fichier :

```
PE TimeDateStamp        Sat Feb  2 23:04:03 1985
ubuntu@ubuntu:~/preuves$ vol -f memoire_active.raw windows.pslist | grep -iE "Facture|PID"

PID     PPID    ImageFileName   Offset(V)       Threads Handles SessionId       Wow64   CreateTime      ExitTime        File output
5620    5628    Facture_Impaye  0x82066e3fb080  3       -       1       False   2026-10-11 16:16:53.000000      N/A     Disabled
ubuntu@ubuntu:~/preuves$
ubuntu@ubuntu:~/preuves$ vol -f memoire_active.raw windows.netscan | grep "10.10.10.5"
0x82066dd96010.0TCPv4   10.10.10.20 scan49910fin10.10.10.5      4444    ESTABLISHED     5620    Facture_Impaye   2026-10-11 16:16:53.000000
ubuntu@ubuntu:~/preuves$ vol -f memoire_active.raw windows.pstree | grep -iE "Facture|explorer|PID"
PID     PPID    ImageFileName   Offset(V)       Threads Handles SessionId       Wow64   CreateTime      ExitTime
** 1440 4992    explorer.exe    0x82066d5a6340  61      -       1       False   2026-10-11 16:08:41.000000      N/A
**** 5620       5628    Facture_Impaye  0x82066e3fb080  3       -       1       False   2026-10-11 16:16:53.000000      N/A
ubuntu@ubuntu:~/preuves$ vol -f memoire_active.raw windows.cmdline | grep -iE "Facture|PID"
PID     Process Args
5620    Facture_Impaye  Required memory at 0x0 is not valid (process exited?)
ubuntu@ubuntu:~/preuves$ vol -f memoire_active.raw windows.dlllist --pid 5620 | head -20
Volatility 3 Framework 2.5.0    PDB scanning finished

PID     Process Base    Size    Name    Path    LoadTime        File output

ubuntu@ubuntu:~/preuves$ vol -f memoire_active.raw windows.malfind --pid 5620 | head -30
Volatility 3 Framework 2.5.0    PDB scanning finished

PID     Process Start VPN       End VPN Tag     Protection      CommitCharge    PrivateMemory   File output     Hexdump Disasm

ubuntu@ubuntu:~/preuves$
```

Figure 14 — Volatility — pslist / netscan / pstree : processus PID 5620, connexion C2 vers 10.10.10.5:4444, et filiation explorer.exe → Facture_Impayee (preuve de l'ouverture par l'utilisateur).

Résultats clés de l'analyse mémoire : le processus malveillant Facture_Impayee.exe (PID 5620) était actif ; il maintenait une connexion ÉTABLIE vers l'attaquant (10.10.10.20:49910 → 10.10.10.5:4444) ; et il a été lancé par explorer.exe, confirmant qu'il a été ouvert manuellement par l'utilisateur (scénario de phishing).

5.8 Détection en temps réel — Wazuh (SIEM)

En parallèle de l'attaque, le SIEM Wazuh a détecté automatiquement l'ensemble de la chaîne d'attaque grâce aux événements Sysmon remontés par l'agent de la victime.

Le tableau de bord Wazuh confirme que l'agent de la victime est actif et affiche le volume d'alertes détectées :

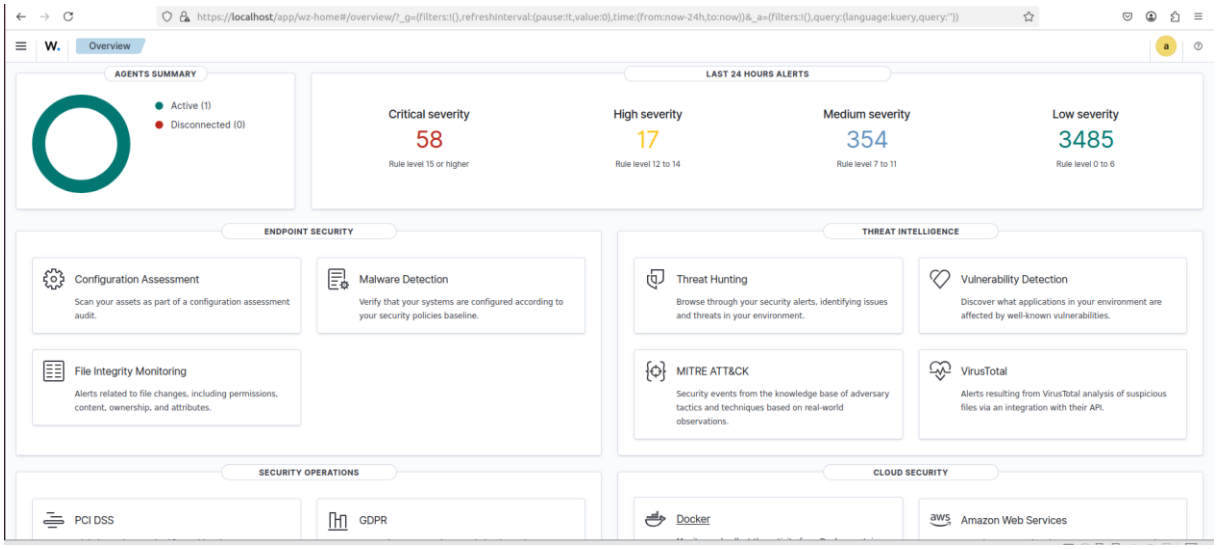


Figure 15 — Vue d'ensemble Wazuh : agent victime actif et 58 alertes critiques détectées sur 24 h.

Wazuh détecte le dépôt de l'exécutable malveillant sur la machine, avec une alerte de niveau 15

	Oct 11, 2026 @ 09:28:37.067	victime-win10	Executable file dropped in folde...	15	92213
	Oct 11, 2026 @ 09:28:35.034	victime-win10	Executable file dropped in folde...	15	92213

Figure 16 — Détection du dépôt du malware : alerte de niveau 15, règle 92213.

Le détail de l'alerte de persistance révèle la clé « WindowsUpdate » pointant vers le malware, identifiée comme technique T1060 (Registry Run Key) :



Figure 17 — Détail de la persistance détectée : clé WindowsUpdate → Facture_Impayee.exe, technique T1060 / RunKey.

Le tableau de bord MITRE ATT&CK caractérise automatiquement l'attaque selon ses tactiques (accès initial, exécution, commande & contrôle, persistance, découverte) :

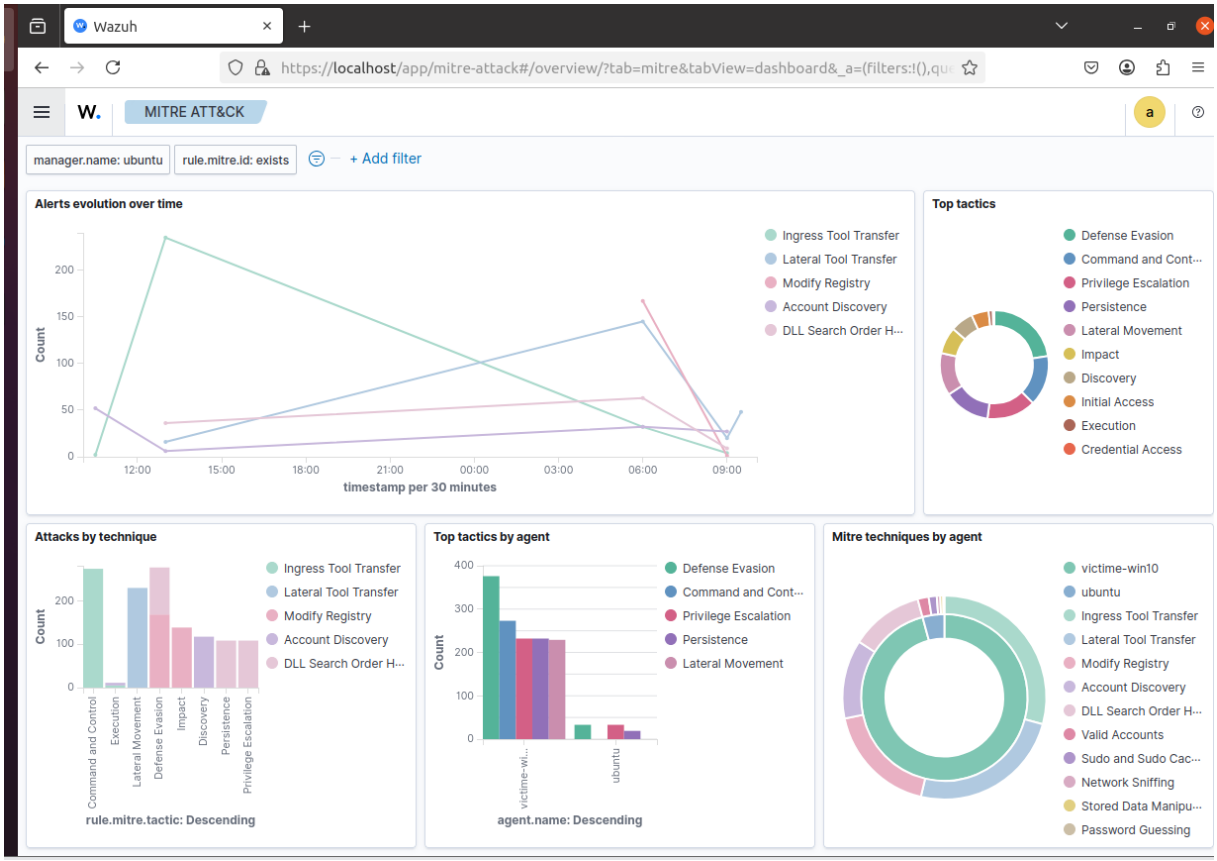


Figure 18— Tableau de bord MITRE ATT&CK de Wazuh : caractérisation automatique de l'attaque (Initial Access, Execution, Command & Control, Persistence, Discovery).

Wazuh a ainsi détecté en temps réel l'intégralité de la chaîne d'attaque : le dépôt de l'exécutable malveillant (règle 92213, niveau 15), la création de la persistance via une clé de registre d'exécution au démarrage (règles 92041 / T1060) et les créations de processus associées (règle 67027). Le tableau de bord MITRE ATT&CK confirme la reconstruction complète de l'attaque.

5.9 Détection réseau — Suricata

L'IDS réseau Suricata, déployé sur la station d'analyse en mode sonde, surveille le trafic et remonte ses alertes dans Wazuh via son fichier eve.json. Cette intégration constitue un véritable tableau de bord unifié combinant détection hôte (Sysmon) et détection réseau (Suricata).

Les alertes réseau générées par Suricata remontent directement dans Wazuh, démontrant l'intégration des deux outils :

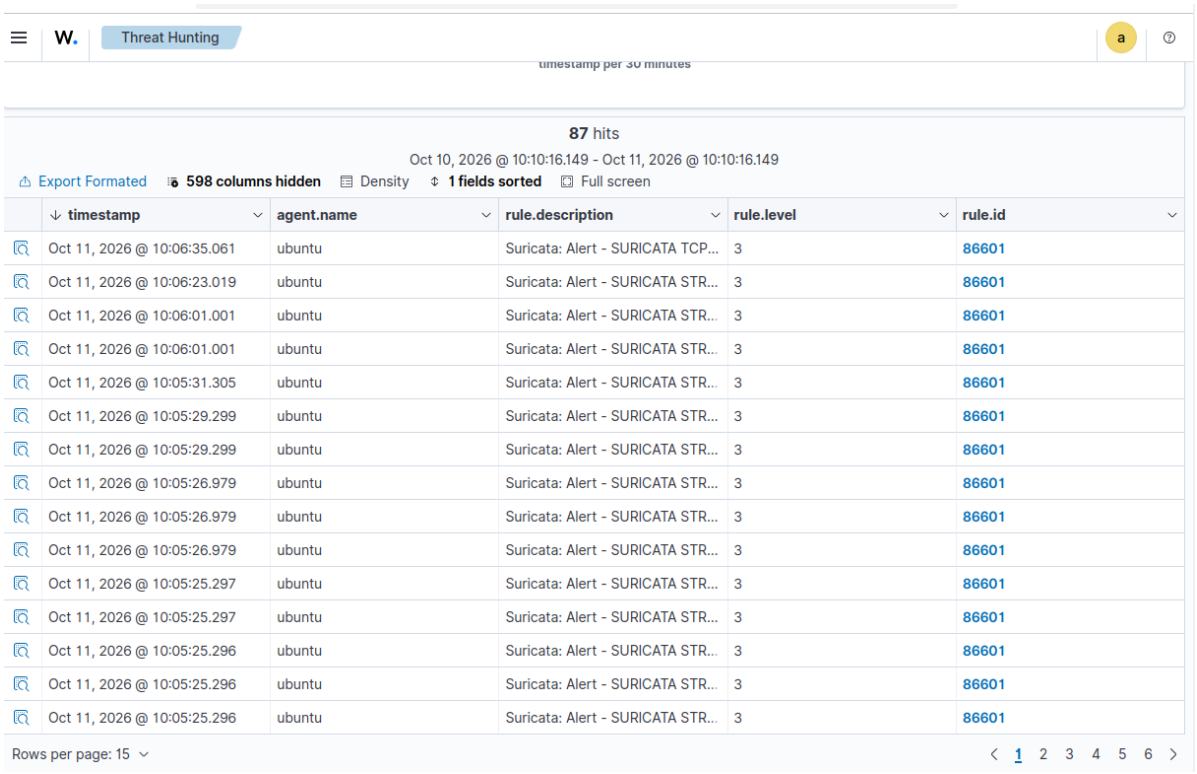


Figure 19 — Alertes réseau Suricata intégrées dans Wazuh (87 alertes, règle 86601).

5.10 Classification du malware — YARA

À partir du processus identifié par Volatility, le fichier malveillant a été récupéré pour analyse. Une règle YARA a été développée, basée sur l'en-tête PE du fichier et la signature caractéristique du shellcode Metasploit x64 (fc 48 83 e4 f0). Appliquée au fichier, elle l'a correctement classifié comme Meterpreter, fournissant une signature réutilisable (IOC).

Le fichier malveillant, identifié par Volatility, est récupéré et son empreinte calculée :

```
ubuntu@ubuntu:~/preuves$ ls -lh Facture_Impayee.exe
-rw-rw-r-- 1 ubuntu ubuntu 7.0K Oct 11 10:13 Facture_Impayee.exe
ubuntu@ubuntu:~/preuves$ sha256sum Facture_Impayee.exe
895ffb729efcda4aa400ea22bf8c527b5388020dc5c3580e18fdc4252d5aab4d  Facture_Impayee.exe
ubuntu@ubuntu:~/preuves$
```

Figure 20 — Récupération du fichier malveillant et calcul de son empreinte SHA-256.

Une règle YARA est alors créée puis appliquée au fichier, qui est correctement reconnu comme un Meterpreter :



Figure 21 — Règle YARA et résultat du scan : le fichier est reconnu comme « Meterpreter_Facture_Impayee ».

6. Indicateurs de compromission (IOCs)

Les indicateurs de compromission (IOCs) sont les traces techniques caractéristiques laissées par l'attaque. Collectés tout au long de l'investigation, ils permettent d'identifier cette compromission et de la rechercher sur d'autres machines afin de vérifier si elles ont été touchées. Le tableau ci-dessous récapitule l'ensemble des IOCs relevés au cours de l'enquête.

Type d'indicateur	Valeur
Fichier malveillant	Facture_Impayee_Octobre2026.exe
Empreinte SHA-256 (malware)	895ffb729efcda4aa400ea22bf8c527b5388020dc5c3580e18fdc4252d5aab4d
Nature du malware	Meterpreter (Metasploit) – Windows x64
Serveur de l'attaquant (C2)	10.10.10.5:4444
Machine victime	10.10.10.20 (DESKTOP-LPFH4I4)
Processus malveillant	Facture_Impayee.exe (PID 5620)
Persistance	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\WindowsUpdate
Fichiers exfiltrés	clients_bancaires.txt, mots_de_passe.txt, contrats.txt

Ces indicateurs constituent une **signature complète de l'attaque**. La règle YARA développée à partir du fichier malveillant (section 5.10) rend d'ailleurs ces indicateurs réutilisables : elle permet de détecter automatiquement ce malware sur l'ensemble d'un parc informatique, transformant les preuves de cet incident en un véritable outil de défense.

7. Risques

L'incident analysé présente une **gravité élevée**, car il combine une compromission totale de la machine et un vol effectif de données. Son impact s'évalue selon les trois grands critères de la sécurité de l'information.

Sur le plan de la **confidentialité**, l'attaque a conduit à l'exfiltration de données sensibles (données bancaires, mots de passe, contrats) : le préjudice est direct et confirmé. Sur le plan de l'**intégrité**, l'installation d'une persistance signifie que l'attaquant conserve un accès durable à la machine et peut y revenir à tout moment, même après un redémarrage ; le système ne peut donc plus être considéré comme sain. Sur le plan de la **disponibilité**, la prise de contrôle à distance via le canal C2 place entièrement la machine sous l'autorité de l'attaquant.

À ces impacts s'ajoute un **risque de propagation** : en environnement réel, l'attaquant pourrait utiliser cette machine comme point d'entrée pour se déplacer vers d'autres postes du réseau (mouvement latéral). L'incident est donc classé comme une **intrusion avec exfiltration de données**, de gravité élevée, nécessitant une réponse immédiate.

Pour objectiver la gravité de l'incident, chaque dimension de la triade CIA est évaluée selon une échelle de 1 (faible) à 5 (critique), combinant probabilité de récurrence et impact métier :

Critère	Impact	Probabilité de récurrence	Score (Impact × Probabilité)
Confidentialité — exfiltration de données sensibles	5 (données bancaires et mots de passe confirmés volés)	4 (technique simple, reproductible sans détection préalable)	**20/25 — Critique**
Intégrité — persistance installée	4 (accès durable, système non fiable tant que non assaini)	3 (nécessite un second accès ou redémarrage pour se déclencher)	**12/25 — Élevé**
Disponibilité — prise de contrôle à distance	3 (machine utilisable par l'attaquant, pas de déni de service observé)	3 (dépend du maintien du canal C2)	**9/25 — Modéré**

Score global de l'incident : 20/25 (Critique), porté par l'exfiltration confirmée de données sensibles. Ce score justifie une réponse immédiate (confinement sous 1 heure) plutôt qu'une remédiation planifiée.

Barème : 1–6 = Faible · 7–12 = Modéré · 13–18 = Élevé · 19–25 = Critique

8. Décisions

Plusieurs décisions ont orienté la conduite de l'investigation afin d'en garantir la rigueur et la validité.

- **Respect de l'ordre de volatilité —** la mémoire vive a été capturée avant toute autre action et avant extinction de la machine, le processus malveillant et la connexion C2 n'existant qu'en mémoire.
- **Recapture mémoire —** la première capture (WinPmem) s'étant révélée inexploitable par les outils de reconstruction, une nouvelle capture a été réalisée avec Magnet RAM Capture pour obtenir un dump propre, analysable par Volatility.
- **Intégrité des preuves —** chaque preuve a été hachée en SHA-256, et l'intégrité du dump mémoire a été re-vérifiée après transfert.
- **Centralisation de l'analyse —** l'ensemble de l'analyse forensique a été consolidé sur la station Ubuntu, simplifiant l'architecture sans perte de capacité.
- **Préservation de l'état —** l'état compromis de la machine a été conservé (snapshots) afin de permettre la démonstration et la rejouabilité de l'attaque.

9. Remédiation

Le plan de remédiation définit les actions de confinement, d'éradication et de reprise. Chaque action répond à un indicateur de compromission identifié lors de l'investigation.

9.1 Confinement

- Isoler la machine victime du réseau.
- Bloquer l'adresse IP de l'attaquant (10.10.10.5) au niveau du pare-feu.
- Interrompre le processus malveillant actif (PID 5620).

9.2 Éradication

Menace (IOC)	Action d'éradication	Vérification
Connexion C2 vers l'attaquant	Blocage pare-feu + arrêt du processus malveillant	Trafic réseau nul
Clé de registre WindowsUpdate	Suppression de la clé	Clé absente (Autoruns)
Facture_Impayee_Octobre2026.exe	Suppression du fichier	Introuvable au scan
Comptes / identifiants exposés	Changement des mots de passe	Accès révoqué

9.3 Reprise

- Restaurer le système depuis une sauvegarde saine (ou le snapshot antérieur à l'attaque).
- Réactiver le réseau uniquement après nettoyage complet.

- Surveiller la machine via Wazuh pour confirmer l'absence de réinfection ou de reconnexion C2.

9.4 Mesures préventives

- Bloquer l'exécution des fichiers exécutables reçus en pièce jointe d'e-mail.
- Restreindre et journaliser l'usage de PowerShell.
- Filtrer les connexions sortantes vers des adresses inconnues.
- Sensibiliser les utilisateurs au phishing.
- Renforcer les règles de détection Wazuh à partir des comportements observés.

10. Conclusion

Ce projet a permis de dérouler un **cycle DFIR complet**, de l'attaque jusqu'à la remédiation, dans un environnement de laboratoire isolé et maîtrisé. Une attaque réaliste — phishing, prise de contrôle à distance, persistance puis exfiltration de données — a été exécutée, détectée en temps réel, puis investiguée de manière forensique afin d'en reconstituer chaque étape.

La détection a reposé sur la complémentarité de deux approches : le SIEM **Wazuh**, qui a capté l'ensemble de la chaîne d'attaque à partir des événements Sysmon et l'a caractérisée selon le référentiel MITRE ATT&CK, et l'IDS **Suricata**, intégré au même tableau de bord pour la surveillance réseau. L'investigation s'est ensuite appuyée sur l'analyse mémoire avec **Volatility**, qui a identifié le processus malveillant et son canal de commande, et sur **YARA**, qui a confirmé et classifié le malware. À chaque étape, une action de l'attaquant a été reliée à une preuve technique vérifiable, et chaque preuve a été protégée par une empreinte garantissant son intégrité.

Au-delà des résultats obtenus, ce projet a mis en évidence des réalités concrètes du métier d'analyste : l'importance de respecter l'ordre de volatilité lors de la collecte, la nécessité d'une capture mémoire propre pour une analyse exploitable, et surtout la **complémentarité des outils**. Aucun d'entre eux ne suffit à lui seul ; c'est en croisant la détection côté machine, l'analyse réseau, l'investigation mémoire et la classification du fichier que l'on parvient à reconstruire et à prouver l'intégralité d'un incident. Cette démarche rigoureuse, où chaque conclusion s'appuie sur une preuve, constitue le cœur même de la réponse à incident et de l'investigation numérique.